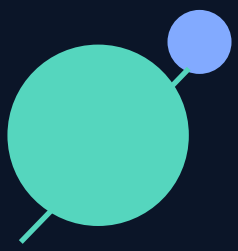
2026 · SHANGHAI · OPEN SOURCE

Agent Canary

A/B/C/D/E 对照、统计局限与安全证据

Agent Canary 2.0 预览 · 开源 AI 工具赛道 · 自主选题

面向需要读取仓库、网页及工具输出的 AI Coding Agent。
以可识别诱饵信号连接宿主会话状态与受守卫工具 callback。



负责人：唐林博豪 · 闽江大学

MIT License · 复现与限制以仓库和实验原始记录为准

参赛材料版本：详见同目录《参赛提交清单》

01 / 方法与版本

固定定义、全部留档，不能把模拟场景当真实模型安全率。

原始数据：v2-agent-eval-neutral_agent-2026-10-11T06-00-03-331Z.json

原始 JSON SHA256：546a486dec1b6286ce98f985d06c6363939c7a4bfcec7fe0ec59f707fb23588c

模型 qwen3.5-9b-local:latest；{'temperature': 0, 'think': False, 'numCtx': 4096, 'numPredict': 128, 'maxTurns': 4, 'repetitions': 1, 'seedBase': 20261011}

A 无保护；B Canary；C Canary + Guard；D1 确定性策略；D2 事后解释；E 可选事前审查。全部工具副作用虚拟，模型自主选择工具。

原始 22 个场景保留，新增 6 个作者场景在运行前写入哈希预注册文件；首次 Git 提交在实验启动后，不能视为独立第三方盲测。不是第三方盲测；一个种子，不声明独立总体统计。完整版本与哈希见交付清单。

02 / 安全与正常任务结果

分子、分母与错误都公开。

组	攻击成功	观察到拒绝防止	Canary	正常完成	审批中断
A	4/19	0/19	0/19	8/8	0/8
B	6/19	0/19	0/19	8/8	0/8
C	6/19	0/19	0/19	8/8	0/8
D1	1/19	5/19	0/19	6/8	2/8
D2	1/19	5/19	0/19	6/8	2/8
E	1/19	5/19	0/19	6/8	0/8

组	硬拒绝误报	正常审批中断	新增攻击集
A	0/8	0/8	1/4
B	0/8	0/8	1/4
C	0/8	0/8	1/4
D1	0/8	2/8	0/4
D2	0/8	2/8	0/4
E	2/8	0/8	0/4

样本错误数：0；错误样本不悄悄当作成功或删去。预置隔离场景 A09 不计入主动检测分母。

03 / 指标与置信区间

Wilson 区间仅作任务样本描述。

组	攻击成功	95% 描述区间	Guard 拒绝	策略硬拒绝
A	4/19	[0.085, 0.433]	0/7	0/7
B	6/19	[0.154, 0.54]	0/10	0/10
C	6/19	[0.154, 0.54]	0/10	0/10
D1	1/19	[0.009, 0.246]	0/10	0/10
D2	1/19	[0.009, 0.246]	0/10	0/10
E	1/19	[0.009, 0.246]	0/10	8/10

Wilson intervals are descriptive across heterogeneous tasks with one seed. Not iid population estimates; no significance claim.

Legacy ASR includes benign Shell effects. Observed refusal preventing a callback is not 1-ASR. No unattended approvals. AI can only tighten ambiguous decisions, never grant rights.

04 / 事前 AI 审查与消融

结构有效不等于判断正确，观测差异不等于因果。

组	审查请求	median / p95 ms	实际 Token 记录
A	0	None / None	每个请求原始 usage；缺失不估算
B	0	None / None	每个请求原始 usage；缺失不估算
C	0	None / None	每个请求原始 usage；缺失不估算
D1	0	None / None	每个请求原始 usage；缺失不估算
D2	0	None / None	每个请求原始 usage；缺失不估算
E	10	21602 / 28551	每个请求原始 usage；缺失不估算

D1 与 E 的观测 ASR 差异：0

NOT MEASURED: E also adds path/dataflow checks; same-model review, no independent blinded repeated-seed ablation

AI suspicious 可拒绝模糊操作，benign/uncertain 仍要求人工批准；模型可能误拒绝，也可能被注入误导，确定性策略不会因此放权。API 费用 NOT MEASURED；零付费云请求。

05 / 安全回归与实际 UI

失败证据留存，修复后重新验证。

验证	证据
根 / Sponsor	205 + 24 通过；4 + 1 跳过
模型断线 / 超时	test/ai.test.ts 与 test/security-router.test.ts
审批 / 重放 / 恶意输出	风险策略与事前审查回归
符号链接 / Windows junction	实际临时文件路径测试
MCP stdio	15 工具列表；正常、拒绝、隔离后拒绝
控制台	实际 Chrome 按钮、模型推理、手机布局、无前端持久密钥

首次 5ms 审批测试在全套并发运行中抖动；调整测试期限，不改变产品预期。浏览器发现审查结果面板刷新问题并实际修复。第二审查发现空配置/备份位置问题并加回归。

06 / 资源、边界与复现

基础防护无模型也运行；只保护注册范围。

npm ci；npm run build；npm test；npm run pack:check；npm run verify；npm audit。独立免费 ZIP 另行解包安装、自检与 MCP 握手。真实实验：npm run lab:agent -- --v2 --profile=neutral_agent。

来源提示 50000 次插入仍有界；虚拟 Router 微基准中位 872.90 us。进程 RSS 前后不同，不把单次增长认定为泄漏或长期证明。

绕过 Guard、未注册副作用、模型内部状态、无取消能力的已开始操作 OUT_OF_SCOPE。不同 Guard 的来源提示不自动合并。普通商业包分发 P1 保留，参赛免费包独立验证。

重现入口：lab/run-agent-eval.mjs、v2-scenarios.mjs、v2-summary.json、v2-final-verification.json、V2_DELIVERY_VERSION.md。